

UNIVERSITÀ DI PARMA
Dipartimento di Ingegneria e Architettura

Firewalls and Intrusion Detection Systems

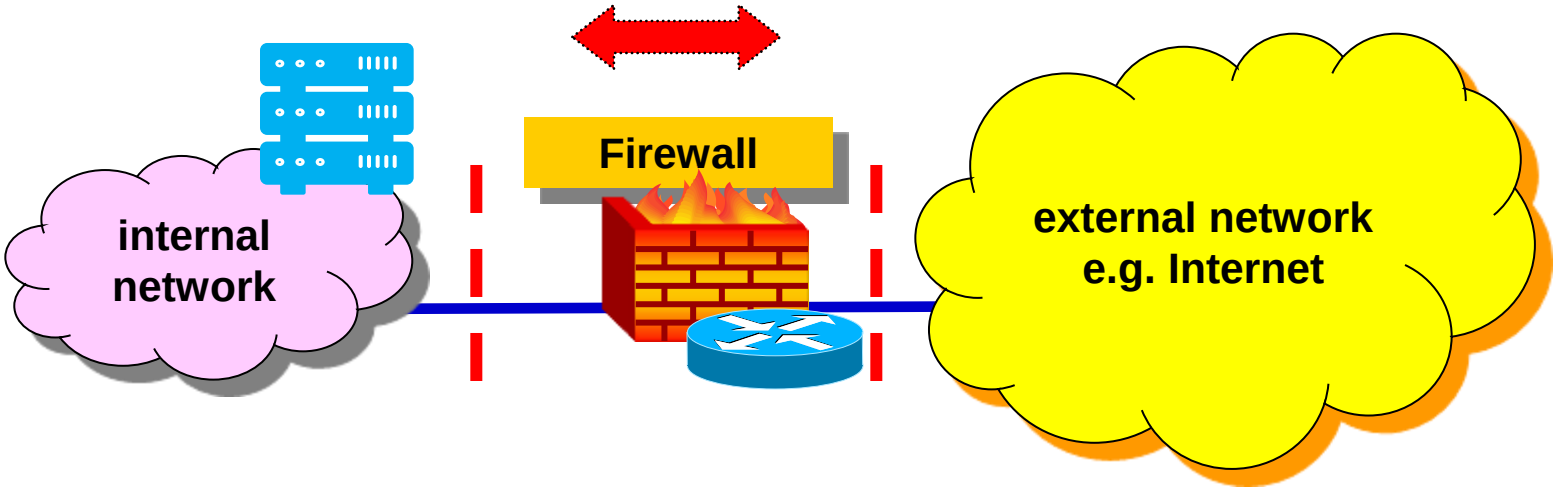
Luca Veltri

(mail.to: luca.veltri@unipr.it)

Course of Cybersecurity, 2025/2026

Firewall

- A firewall is security system that controls the incoming and outgoing network traffic
  - **by analyzing the data packets and determining whether they should be allowed through or not, based on a rule set**
  - **builds a bridge between a system (an internal network or computer) and an external network**
  - **can be implemented in HW or SW**



Examples of firewalls

- Many routers that pass data between networks contain firewall components
  - **packet filtering (or screening) router**
- Also intermediate systems working at network or application level may acts as firewall
  - **NAT**
  - **Application Level Gateways (e.g. proxies)**
- Many personal computer OSs include software-based firewalls to protect against threats from the attached network and/or from the public Internet
  - **personal firewalls**
- Example: Linux iptables
  - may work as both personal firewall or router firewall

Firewall classification

- There are different types of firewalls depending on where the communication is taking place, where the communication is intercepted and the state that is being traced
  - **Network layer or packet filters**
    - Level 3-4 switches
    - Screening routers
    - Network address translation nodes
      - NATs and NAPTs
  - **Application-layer firewalls**
    - Host-based application firewalls
    - Network-based application firewalls
      - Single-interface bastion hosts
      - Dual-homed systems

When a firewall does not guarantee security

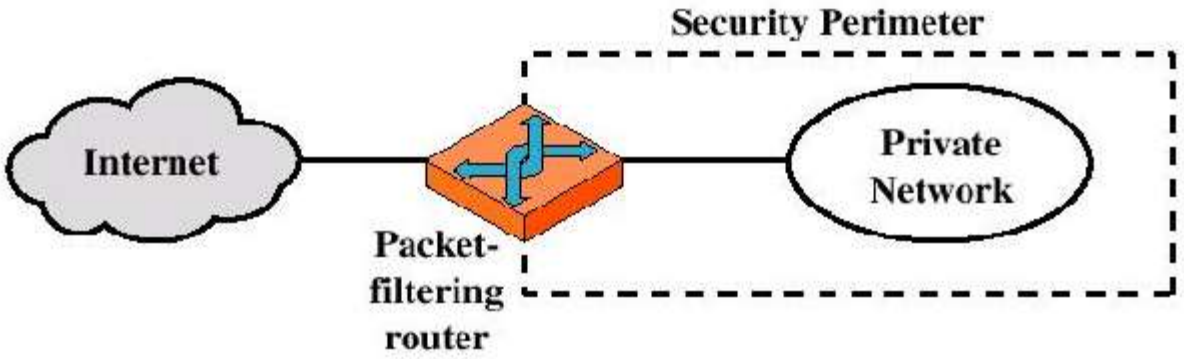
- In case of errors or firewall misconfigurations
  - **the firewall does not correctly implement the defined security policies**
- The system where the firewall is installed is vulnerable
  - **due to bugs or misconfiguration of the OS or other applications**
- Presence of other paths between the external and internal networks, by-passing the firewall, e.g.
  - **wireless (WiFi) Access Points connected to the internal network, not protected by the firewall**
  - **internal computers/smartphones with 3/4/5G connections**
- Attacks that start from internal system
  - **malicious users**
  - **caused by compromised mobile computers (laptops, tablets, smarthphones)**
  - **caused by software starting from removable disks / memory sticks**

Packet Filters

Packet filters

- Also referred to as network layer firewalls
- They operate at a relatively low level of the protocol stack, not allowing single packets to pass through the firewall unless they match the established rule set
  - **can filter traffic based on many packet attributes like**
    - source/destination IP addresses,
    - transport protocol,
    - source/destination ports,
    - input/output interfaces,
    - many other packet header fields and attributes
  - **filter rules may be defined by a firewall administrator, or default rules may apply**

Packet Filtering Router



- IP router with filtering capabilities
  - **also referred to as Screening Router**
- Applies a set of rules to each incoming IP packet and then forwards or discards the packet
  - **filter packets going in both directions**
  - **it is typically set up as a list of rules based on matches to fields in the IP and/or transport headers**
  - **two default policies (discard or forward)**

Filtering rules: Example

- Filtering rules are listed in proper lists or tables, sometimes referred to as *Access control lists*, or *Chains*
- Example:
  - **enabling traffic towards and from a mail server (SMTP) and web server (HTTP)**

IP source	*IP dest*	*Proto*	*Sorce port*	*Dest port*	*Action*
*	160.78.1.1	tcp	> 1023	25	permit
*	160.78 .1.2	tcp	> 1023	80	permit
160.78 .1.0/24	*	*	*	*	permit
*	*	*	*	*	deny

Packet Filtering Operation



incoming packet

inspection of header and data

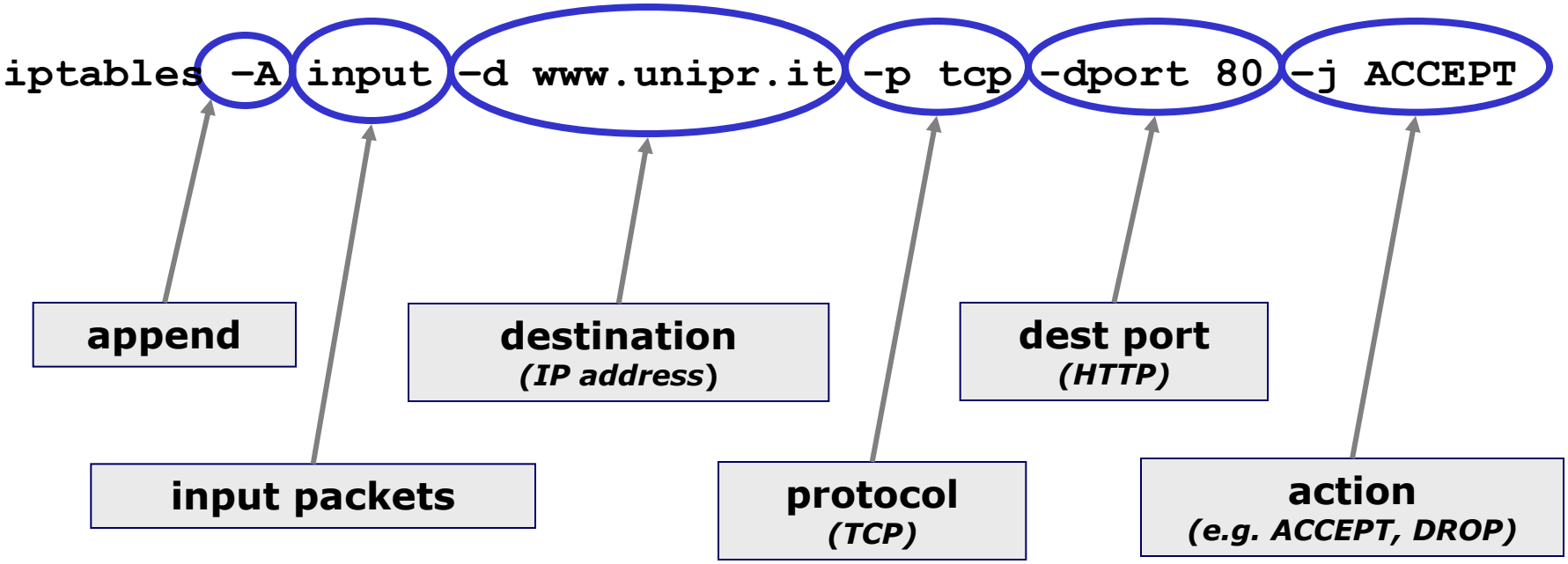
enforcing of filtering rules



access control lists

Actions: routing, drop, log, jump to an other list, others

Example of insertion of filtering rules



Stateless vs Stateful packet filters

- Generally fall into two sub-categories: stateless and stateful
  - **Stateless packet filter**
    - decision is per-packet based
      - no state related on previously processed packet
    - require less memory, and can be fast
    - cannot make complex decisions based on what stage communications between hosts have reached
  - **Stateful packet filter**
    - maintain context about active sessions, and use that "state information" to process packets
      - any existing communication is characterized by several properties (source and dest addresses, UDP/TCP ports, connection lifetime, etc.)
      - a firewall's state table is maintained and it contains state (connection) information relate to accepted packets
      - a packet matches an existing connection based on comparison with the state table
      - if a packet does not match an existing connection, it will be evaluated according to the ruleset for new connections

Packet Filters – Advantages/Disadvantages

- Advantages:
  - **Simplicity**
  - **High speed**
  - **Transparency to users**

- Disadvantages:
  - **Difficulty of setting up packet filter rules**
  - **Lack of authentication**

Application-Layer Firewalls

Application-layer firewalls

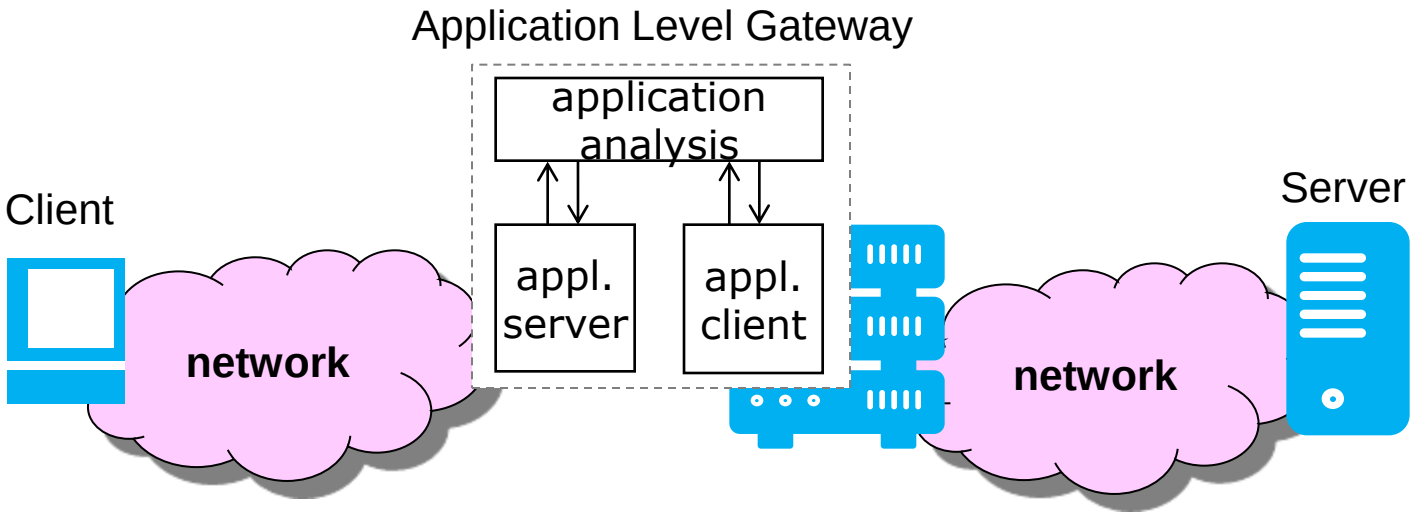
- An application firewall is a form of firewall which controls input, output, and/or access from, to, or by an application or service
  - **can control all network traffic data up to the application layer**
    - it may inspect the contents of traffic, blocking specified content
      - such as certain websites, malicious programs, or attempts to exploit known logical flaws in client software
      - can restrict or prevent the spread of computer malwares
    - unlike a stateful packet filter firewall which is (without additional software) unable to control network traffic regarding a specific application
- There are two primary categories of application firewalls
  - **host-based application firewalls**
  - **network-based application firewalls**

Host-based application firewalls

- A host-based application firewall provides protection to the applications running on the same host
- It can monitor any application input, output, and/or system calls made from, to, or by the application
  - **this is done by examining information passed through system calls instead of or in addition to a network stack**
  - **it may block the input, output, or system calls (including socket calls) which do not meet the configured policy of the firewal**
  - **they are able to apply filtering rules (allow/block) on a per process basis instead of filtering connections on a per port basis**
  - **generally, prompts are used to define rules for processes that have not yet received a connection**

Network-based application firewalls

- A network-based application layer firewall operates at the application layer of an (application) intermediate node
  - **also known as proxy-based firewall or application-level gateway**
  - **it acts as a proxy/gateway for specific applications**
    - specific to a particular kind of network traffic
      - e.g. WAF (web application FW), HTTP and FTP proxy, SMTP server, SIP proxy
    - can act as either forward or reverse proxies



Network-based application firewalls (cont.)

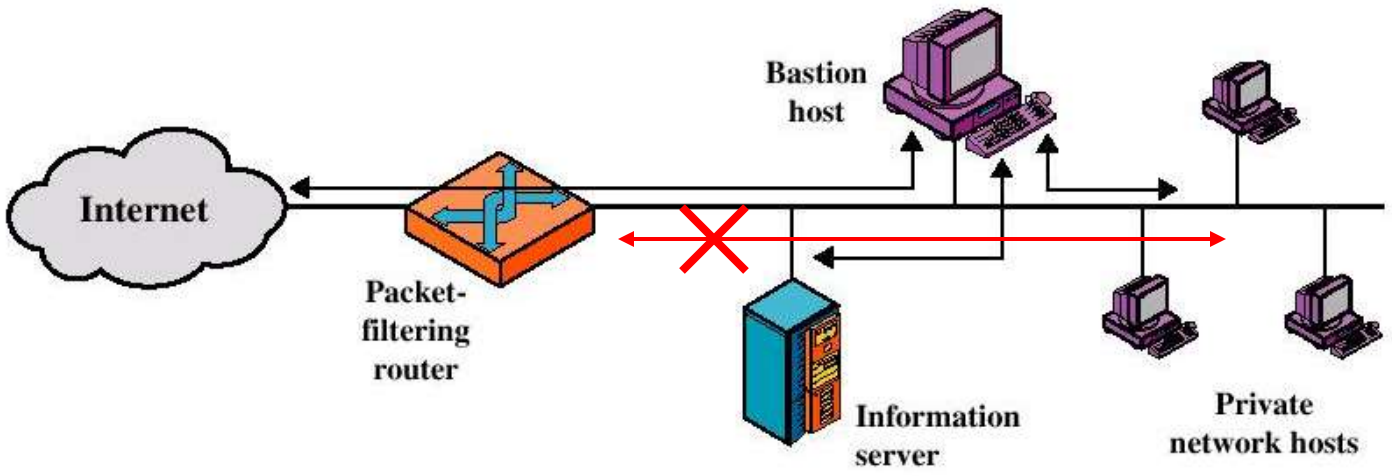
- May run either as a stand-alone piece of network (dedicated) hardware, or as software on a general-purpose machine
  - **often, it is a host using various forms of proxy servers to proxy traffic before passing it on to the client or server**
- May run as single-homed host or on a dual-homed host

Network-based application firewalls (cont.)

- Advantages:
  - **full control at application level**
    - content filtering
    - strong user authentication
    - higher level of security respect to a packet filter
  - **easy to log and audit all incoming traffic**
  - **by default, internal addresses are hidden**
  - **caching**
- Disadvantages:
  - **worse performances**
    - additional processing overhead on each connection
  - **often requires explicit client configurations**
  - **not suitable for new services/applications**
    - does support ONLY services for whjch a corresponding proxy is available (FTP, Telnet, HTTP, SMTP, …)

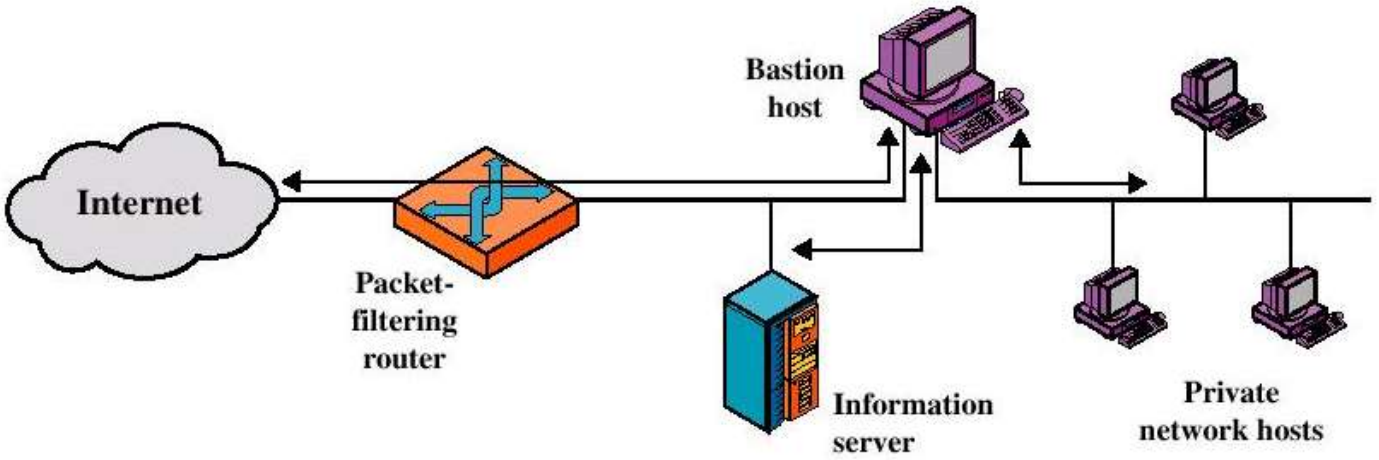
Hybrid configurations

Screened host firewall (single-homed bastion host)



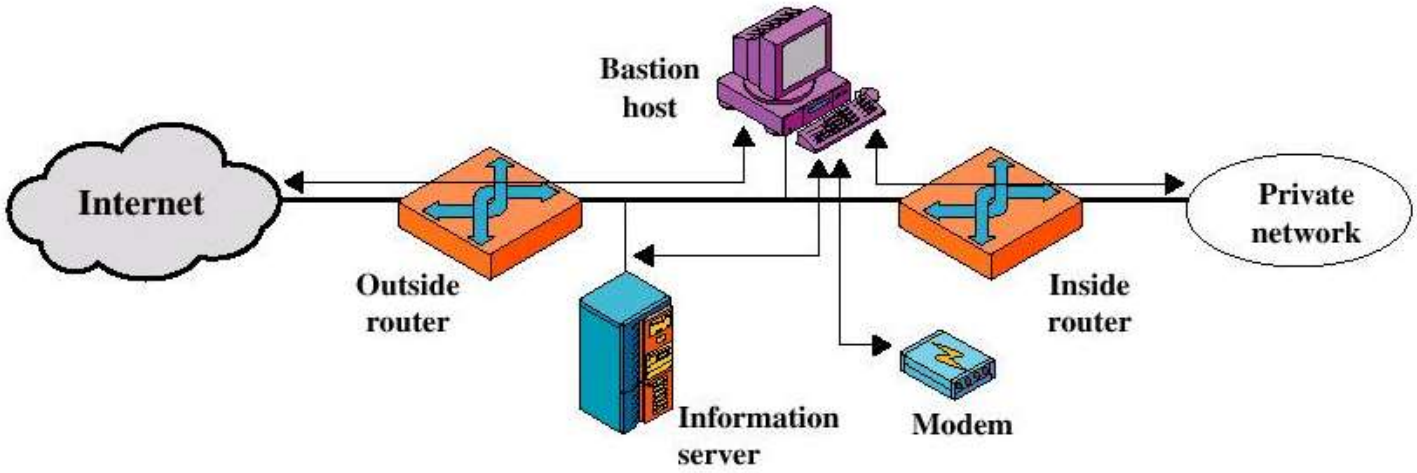
- Screened host firewall, single-homed bastion configuration
- The firewall consists by two systems:
  - **A packet-filtering router**
  - **A bastion host**

Screened host firewall (dual-homed bastion host)



- Screened host firewall, dual-homed bastion configuration
  - **Traffic between the Internet and other hosts on the private network has to flow through the bastion host**
    - regardless the router configuration
  - **If the packet-filtering router is compromised, the network is still not completely compromised**

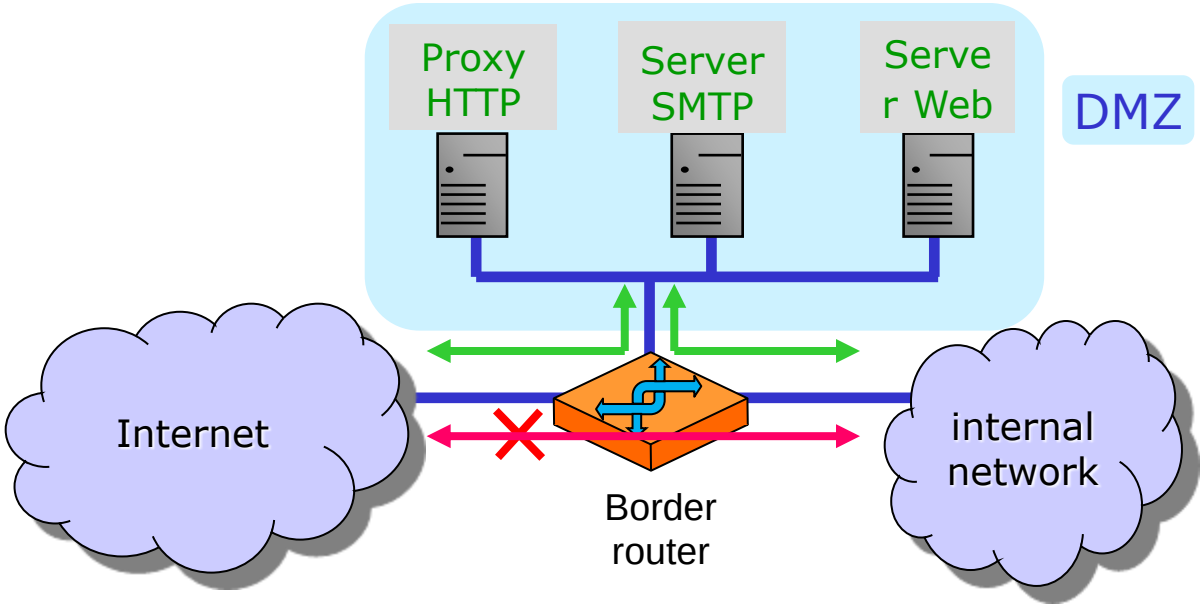
Screened-subnet firewall



- Screened subnet firewall configuration
  - **Most secure configuration**
  - **Two packet-filtering routers are used**
  - **Creation of an isolated sub-network (DMZ)**

Screened-subnet firewall (cont.)

- Merging of interior/exterior router



Intrusion Detection System (IDS)

Intrusion Detection System (IDS)

- IDSs are software or hardware systems that automate the process of monitoring the events occurring in a computer system or network, analyzing them for signs of intrusions
  - **try to discover attempts to compromise or to bypass the security mechanisms of a computer or network**
  - **generate data as a consequence of normal or abnormal usage**
- IDSs process a stream of events *E1, E2, E3, …,* and past system states *S1, S2, S3,…*, and decide if a new event *E4* in *S4* is the final evidence that an intrusion is occurring
  - **they analyze the manifestation of an attack, not the result of the attack**
- An IDS may try to detect different types of intrusions:
  - **external attackers trying to access a system**
  - **authorized users of the systems who attempt to gain additional privileges for which they are not authorized**
  - **authorized users who misuse the privileges given them**

Network based IDS

- They detect attacks by capturing and analyzing network packets
  - **monitoring a network segment or switch they can protect multiple host**
- Often consist of a set of single-purpose nodes (called sensors) or hosts placed at various points in a network
  - **sensor can run in "stealth" mode**
- Majority of commercial IDSs
- Advantages:
  - **few placed IDSs can monitor a large network**
  - **little impact upon an existing network**
    - NIDSs are usually passive devices that listen on a network wire without interfering with the normal operation of a network
  - **can be made very secure against attack and even made invisible to many attackers**

Network based IDS

- Disadvantages
  - **may have difficulty in processing all packets in a large or busy network**
    - HW implementation of a NIDS may help
  - **switched networks**
    - networks are subdivided into many small segments (usually one wire per host)
    - most switches do not provide universal monitoring ports
  - **cannot analyze encrypted information**
  - **problems dealing with attacks that fragment packets**
  - **often they cannot tell whether or not an attack was successful**
    - administrators must manually investigate each attacked host to determine whether it was indeed penetrated

Host based IDS

- Operate on information collected from within an individual computer system
  - **application-based IDSs are actually a subset**
  - **great reliability and precision, determining exactly which processes and users are involved in a particular attack on the operating system**
- Two types of information sources
  - **operating system audit trails**
    - usually generated at the innermost (kernel) level of the OS
    - more detailed and better protected than application logs
  - **application logs**
    - much smaller than OS trails
    - far easier to comprehend

Host based IDS

- Advantages
  - **detection of attacks that cannot be seen by a NIDS**
    - e.g. can help detect attacks involving software integrity holes
      - appear as inconsistencies in process execution
  - **they can "see" the outcome of an attempted attack**
    - they can directly access and monitor the data files and system processes usually targeted by attacks
  - **they are unaffected by switched networks and encrypted traffic**
- Disadvantages
  - **harder to manage, as information must be managed for every host monitored**
    - not well suited for detecting surveillance for an entire network
    - the amount of information can be immense
  - **use of the computing resources of the hosts they are monitoring**
  - **the IDS may be attacked and disabled as part of the attack (hosted by the systems it is monitoring)**

Tools that complement IDS

- Vulnerability Analysis/Assessment Systems
  - **tools to determine whether a network or host is vulnerable to known attacks**
  - **network-based (remote) analysis**
    - testing by exploit
    - inference method (looking for the artifacts that successful attacks would leave behind)
  - **e.g. Nessus, OpenVAS**

- Honeypot System
  - **system that look like a vulnerable system**

